AccuKnox

Keep every secret out of your code

Six practices to find leaked keys, store them in one place and serve them at runtime with AccuKnox Secrets Manager.



The problem

Leaked secrets stay valid for years

Developers commit keys, tokens and passwords faster than teams revoke them. An attacker who finds one valid key logs in with no exploit at all.

28.65M

New hardcoded secrets added to public GitHub commits in 2025, up 34% year over year.

Source. GitGuardian, State of Secrets Sprawl 2026

64%

Of the secrets confirmed valid in 2022 were still valid when GitGuardian retested them in January 2026.

Source. GitGuardian, State of Secrets Sprawl 2026

94 days

The median time to remediate leaked secrets found in a GitHub repository.

Source. Verizon, 2025 DBIR Executive Summary

Detection alone does not close the gap. A leaked key stays dangerous until someone revokes it, and most teams avoid rotation because a password change can break production.

Root causes

Secrets leak where teams feel safe

Four habits put live credentials in places no scanner or reviewer checks.

01

Private repositories feel safe. Internal repos are roughly 6 times more likely than public ones to hold hardcoded secrets, because the exposure feels far away.

02

Secrets travel outside code. About 28% of incidents start entirely outside repositories, in Slack, Jira and Confluence. A code scanner never reads them.

03

Pipelines hold live keys. In one supply chain attack dataset, 59% of the compromised machines were CI/CD runners, not personal laptops.

04

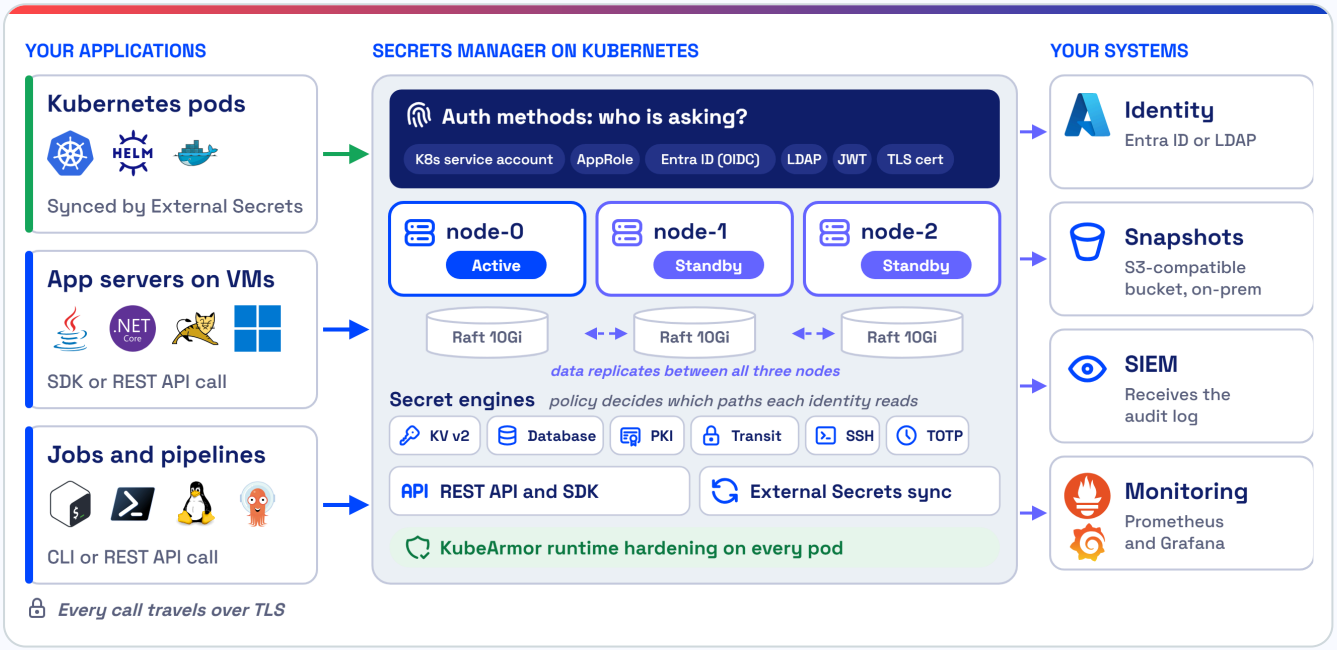
Rotation feels risky. A key with no owner and no rotation path stays in place, because nobody knows which service breaks when it changes.

Sources. Rows 01 to 03, GitGuardian, State of Secrets Sprawl 2026.

Start here

Six practices close the secrets gap

Practice 01 runs in the AccuKnox platform as Secret Scanning. Practices 02 to 06 run in AccuKnox Secrets Manager, which installs on its own on any Kubernetes cluster at version 1.30 or later.



Secrets Manager architecture. help.accuknox.com/secrets-manager/architecture

01 **Find leaked secrets** 05
Scan code and pipelines first

02 **Centralize storage** 06
One encrypted store with versions

03 **Deliver at runtime** 07
No secrets in env files or code

04 **Rotate and expire** 08
Versions and short lived credentials

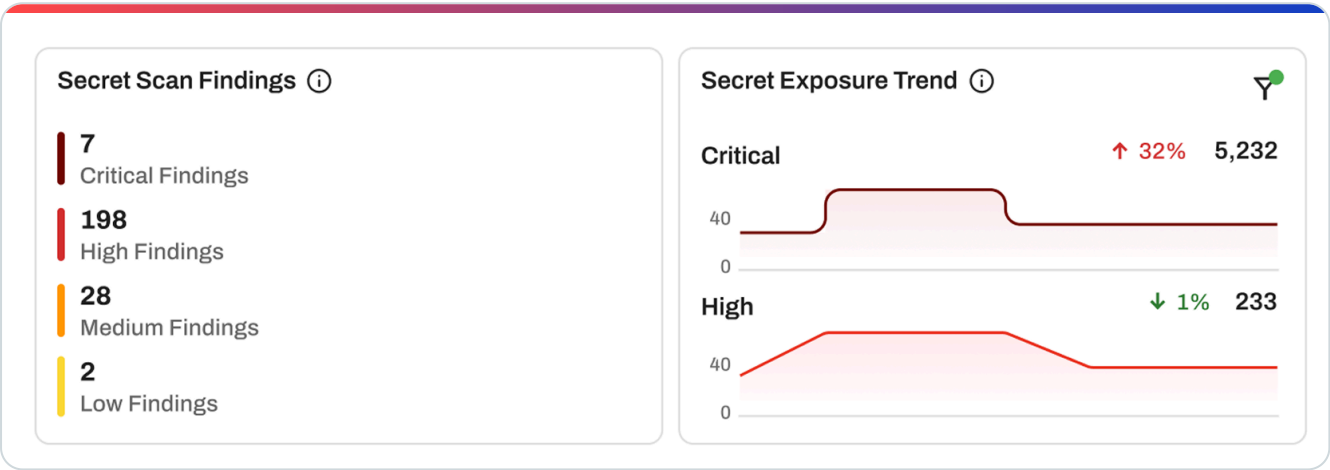
05 **Scope each app** 09
One policy, one path, full audit

06 **Run it resilient** 10
HA, snapshots, air gapped install

Practice 01

Find the secrets you already leaked

AccuKnox Secret Scanning reads every repository with its full commit history, and fails the build when it finds a key.



Secret Scan Findings dashboard. help.accuknox.com/use-cases/secret-scan-cicd-aws

DO

- Scan the full git history, because a key you deleted still sits in old commits.
- Run the scan on every pull request and push, and fail the build on a finding.
- Filter **Issues** > **Findings** by Secret Scan, then open a Jira or ServiceNow ticket per leak.
- Revoke and rotate the key first, then purge it from history with BFG Repo Cleaner.

DON'T

- Don't rely on grep or peer review. Reviewers read code for function, not for keys.
- Don't skip private repositories. They hold more secrets than public ones.
- Don't close a finding when you delete the file. The key stays valid until you revoke it.

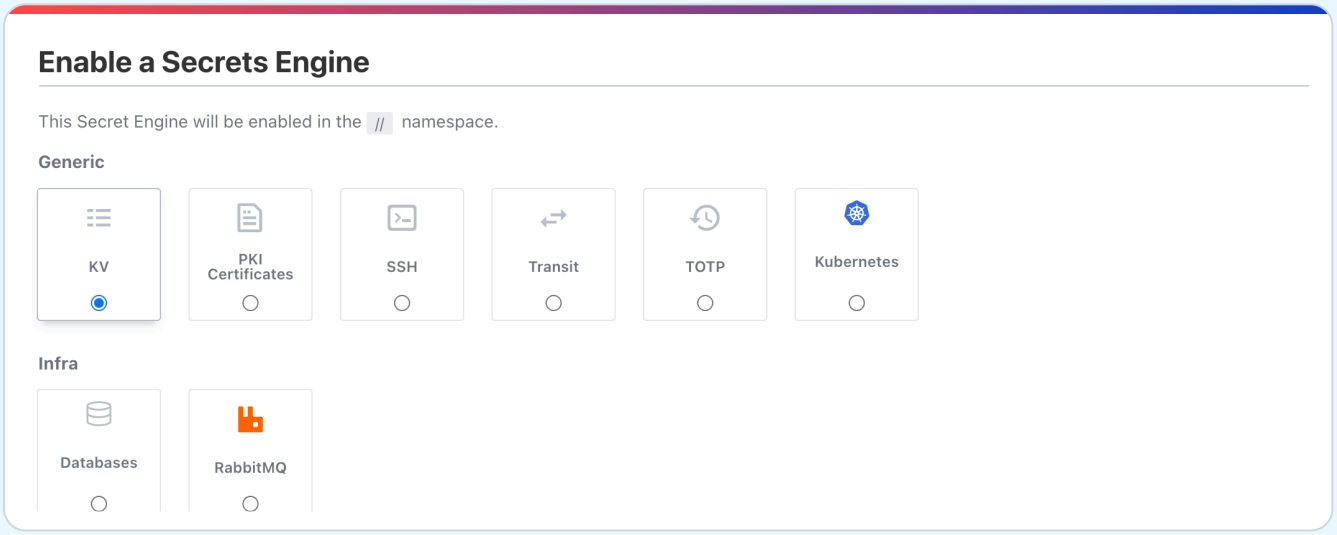
HOW ACCUKNOX CLOSES THE GAP

Secret Scanning runs in GitHub Actions, GitLab, Jenkins, Bitbucket, CircleCI and more. Each finding shows the secret type, file path, commit SHA and committer. Add secret scanning to CI/CD

Practice 02

Keep every secret in one store

Secrets Manager holds passwords, API keys, tokens, certificates and one time codes behind policy, and encrypts them before they reach disk.



Enable a Secrets Engine screen. help.accuknox.com/secrets-manager/kv-secrets

DO

- Move every static secret into the KV version 2 engine, which keeps versions and rollback.
- Create one path per team, environment or component, such as frontend, backend or database.
- Use the PKI engine for certificates and the TOTP engine for shared MFA accounts.
- Send a one off value as Transit ciphertext, so the plaintext never travels.

DON'T

- Don't pass credentials around in chat, email or spreadsheets.
- Don't use the root token for daily work. Retire it after you create the first admin.
- Don't treat delete as destroy. A deleted version stays recoverable until you destroy it.

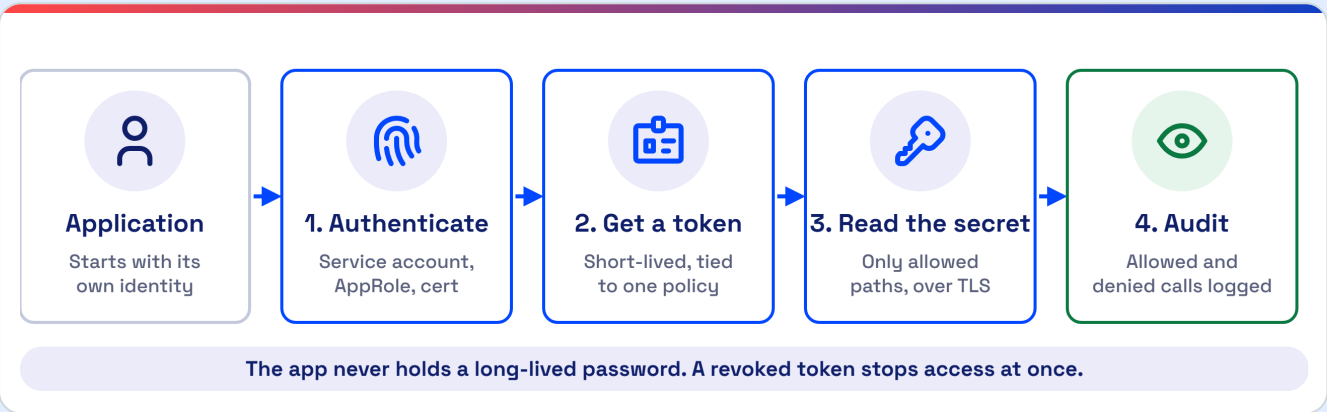
HOW ACCUKNOX CLOSES THE GAP

Secrets Manager keeps Vault compatible APIs, so most Vault applications move to the new endpoint with minimal changes. Store your first secret

Practice 03

Serve secrets at runtime, not from env files

The application proves who it is, gets a short lived token and reads the secret straight into memory.



The four steps of a secret request. help.accuknox.com/secrets-manager/connect-applications

DO

- Read secrets through the SDK or REST API when the value must stay out of the namespace.
- Log pods in with their Kubernetes service account, so the pod stores no credential.
- Use AppRole off Kubernetes, and hand over the secret ID at deploy time through your pipeline.
- Use the External Secrets Operator when you cannot change the application code.

DON'T

- Don't write a secret value to a log.
- Don't commit an AppRole secret ID to source code. It works like a password.
- Don't assume the operator hides the value. Anyone who can read the namespace can read the synced secret.

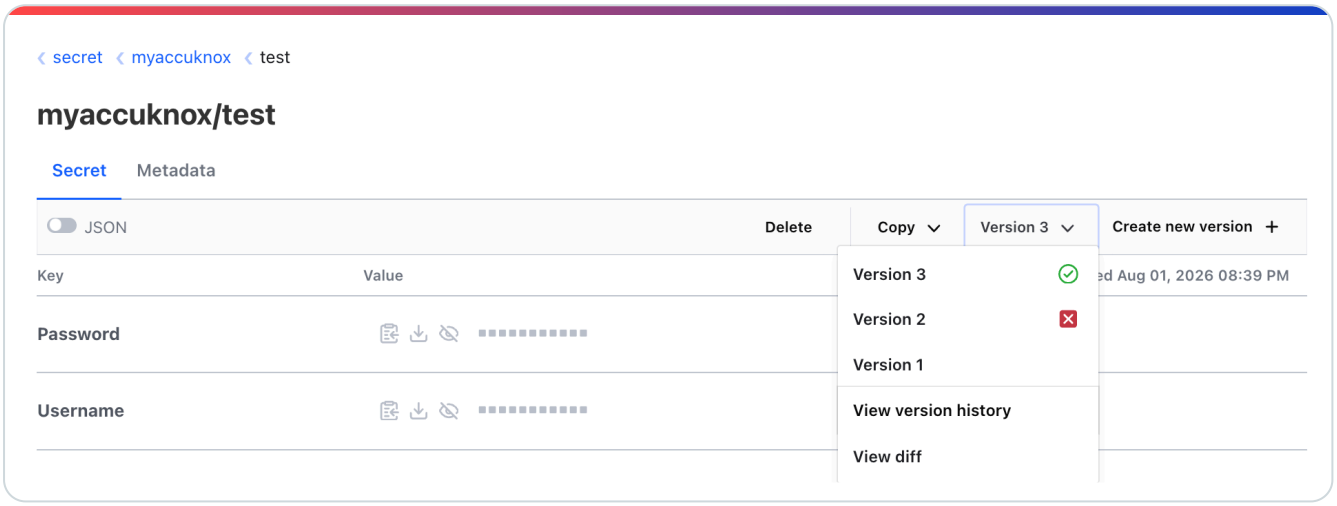
HOW ACCUKNOX CLOSES THE GAP

The SDK keeps the secret in application memory only, on Kubernetes and VMs, with samples for Python, Java, .NET and Node.js. Choose a connection method

Practice 04

Rotate secrets and keep credentials short lived

A new version in Secrets Manager reaches Kubernetes within the refresh interval you set, with no manual edit.



Version history of a KV secret. help.accuknox.com/secrets-manager/kv-secrets

DO

- Rotate by saving a new version, and keep earlier versions for rollback.
- Use the Database engine for short lived database credentials instead of a static password.
- Set a **refreshInterval** on each ExternalSecret, such as 10s, so Kubernetes follows the store.
- Plan a rolling restart after each change, because the app reads the value at startup.

DON'T

- Don't expect a running pod to reload a synced secret on its own.
- Don't leave an old session open after a leak. Revoke the token under **Access** > **Tokens**.
- Don't assume a policy change applies at once. An older token keeps its old policies until the holder signs in again.

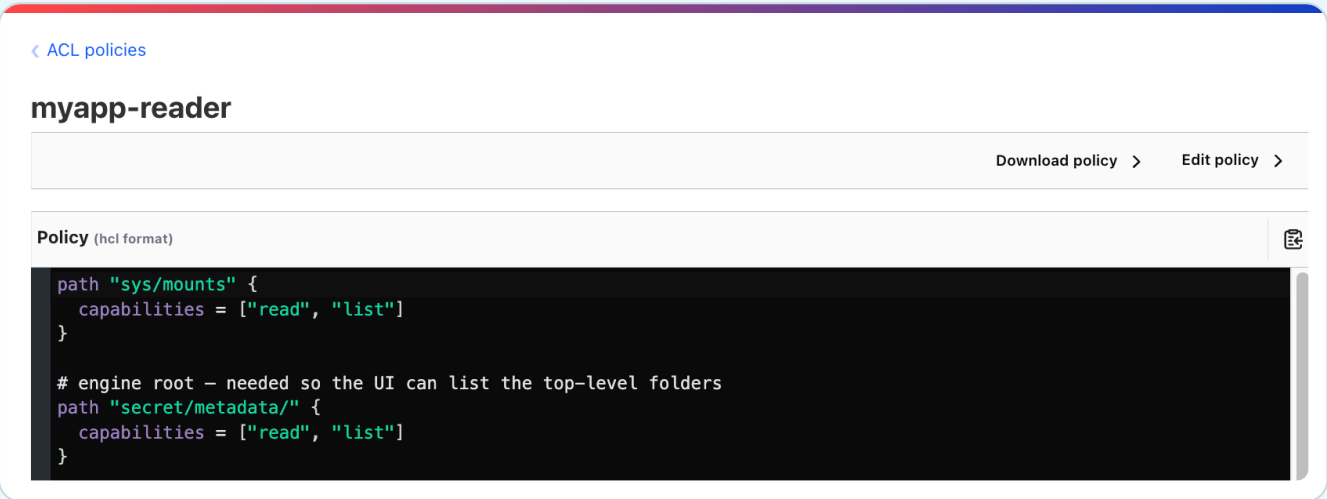
HOW ACCUKNOX CLOSES THE GAP

Leases and renewal policies rotate dynamic credentials automatically. The WordPress and MySQL walkthrough shows a password change end to end. Follow the walkthrough

Practice 05

Give each app only its own paths

An ACL policy names the exact paths an identity may read, and Secrets Manager logs every allowed and denied call.



An ACL policy scoped to one folder. help.accuknox.com/secrets-manager/sharing-secrets

DO

- Write one policy per application, and name its folder in every path.
- Give a second application its own namespace scoped SecretStore and role.
- Test each account. Read an allowed path, then confirm a path outside the policy is denied.
- Keep the audit log on its own volume and forward it to your SIEM.

DON'T

- Don't grant **secret/data/***. It opens every secret in the engine.
- Don't share one account across a team. Give each person a scoped user.
- Don't read **ReadWrite** in the operator status as a grant. The role's policy decides access.

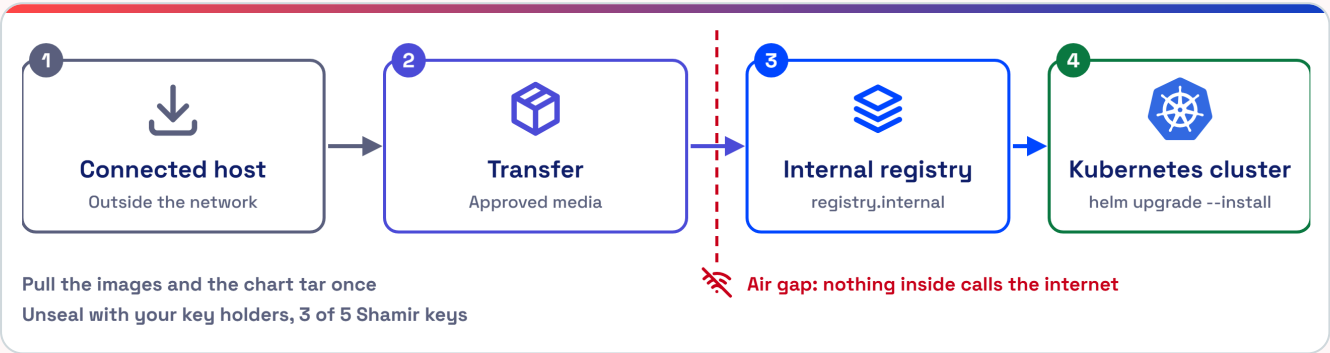
HOW ACCUKNOX CLOSES THE GAP

Pods, VMs and people sign in through Kubernetes auth, AppRole, TLS certificates, OIDC with Microsoft Entra ID, LDAP, Okta or JWT. Scope access per user

Practice 06

Run the store highly available and air gapped

Three nodes survive the loss of one, snapshots run every 15 minutes, and the install needs no internet access.



Air gapped install flow. help.accuknox.com/secrets-manager/air-gapped

DO

- Run three replicas on Raft storage, with each pod on its own host.
- Turn on the snapshot agent. It writes to an S3 compatible bucket every 15 minutes and keeps 14 days.
- Mirror the images to an internal registry and install from the chart tar file.
- Give the 5 unseal key shares to different people, so any 3 unseal the server offline.

DON'T

- Don't keep every unseal key with one person. Without 3 of the 5 keys the data is lost.
- Don't expect HA to add throughput. Every write goes through the leader.
- Don't run the store without runtime hardening. It holds the keys to every other app.

HOW ACCUKNOX CLOSES THE GAP

AccuKnox CWPP, built on KubeArmor, hardens every Secrets Manager pod and limits what its processes can read and run. Set up high availability

Gap check

Find your gap, then take the first step

Read each row. Where the condition is true for you, take the first step this week.

IF THIS IS TRUE	ACCUKNOX CAPABILITY	FIRST STEP
Keys sit in repositories or in old commits	Secret Scanning	Add the scan to every pull request and fail the build on a finding
Credentials live in env files, chat or spreadsheets	Secrets Manager KV engine	Move each secret to one KV version 2 path per component
Apps read secrets from plaintext config	SDK or External Secrets Operator	Connect one app with the method that fits it
Nobody knows when a password last changed	Versions and the Database engine	Rotate one database password, then restart the app
One token reads every secret	ACL policies and auth methods	Replace **secret/data/*** with one policy per app
The store runs as one pod with no backup	HA, snapshots and KubeArmor	Enable three replicas and the snapshot agent

AccuKnox

See Secrets Manager on your cluster

Book a demo and bring your gap check. We show the install, a scoped policy and a live app connection on Kubernetes.

Book a demo

Read the Secrets Manager docs

KuppingerCole

Featured in the 2026 CNAPP Leadership Compass.

accuknox.com/analyst-recognition

Security BSides

Ranked first AI security startup of 2025 in Bangalore.

accuknox.com/press-release

KubeArmor

The AccuKnox CNCF sandbox project that hardens every Secrets Manager pod.

help.accuknox.com/use-cases/hashicorp

Vault compatible

Existing Vault applications move with minimal changes.

help.accuknox.com/faqs/secrets-manager

accuknox.com · © 2026 AccuKnox, Inc.